

Лабораторно упражнение №2

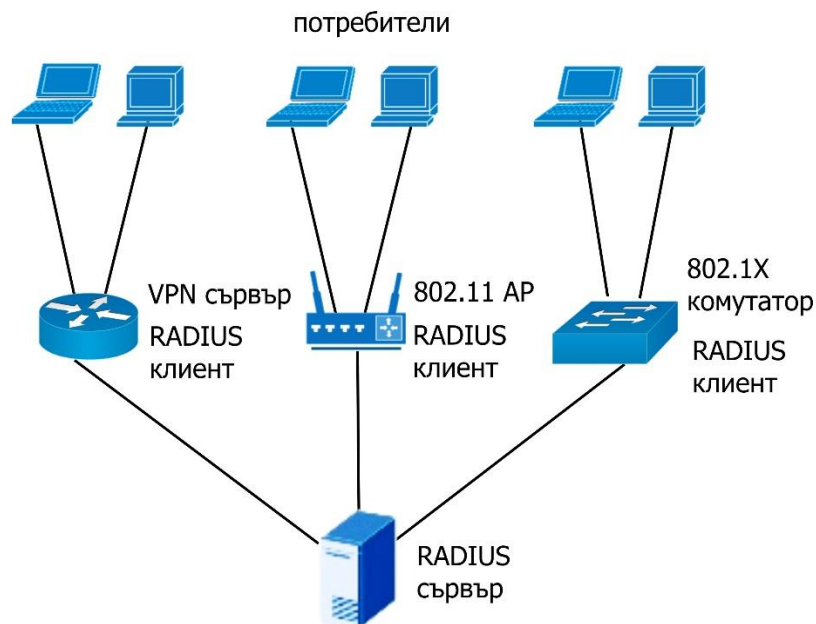
Администриране на Windows Server 2016

Централизиран контрол на достъпа на потребители чрез RADIUS протокол

1. Кратки сведения

RADIUS (*Remote Authentication Dial-in User Service*) представлява мрежов протокол от тип клиент-сервър, позволяващ централизирано управление на достъпа на потребители чрез удостоверяване, упълномощаване и управление (*Authentication, Authorization & Accounting, AAA*). Протоколът е дефиниран първоначално в стандартите IETF RFC 2865 и 2866. RADIUS работи на приложния слой и използва UDP портове 1812 и 1813 на транспортния слой. Ключови особености на RADIUS протокола са:

- Системите, работещи като сервъри за мрежов достъп (*Network Access Server, NAS*), представляват RADIUS клиенти - напр. безжични точки за достъп, VPN сервъри, 802.1x комутатори и др. (фиг.1.1). Те са отговорни за пренасочване на заявките за удостоверяване на потребителите към назначени RADIUS сервъри и не извършват процеси по обработка на самите заявки.
- RADIUS сервърите са отговорни за събиране на потребителските заявки, удостоверяване на потребителите и в последствие изпращане на нужната конфигурационна информация, нужна на RADIUS клиентите да осигуряват мрежови услуги на потребителите.
- Даден RADIUS сервър е в състояние да играе ролята на прокси клиент към други RADIUS сервъри или друг тип сервъри за удостоверяване.



Фиг.1.1. RADIUS сървър и RADIUS клиенти

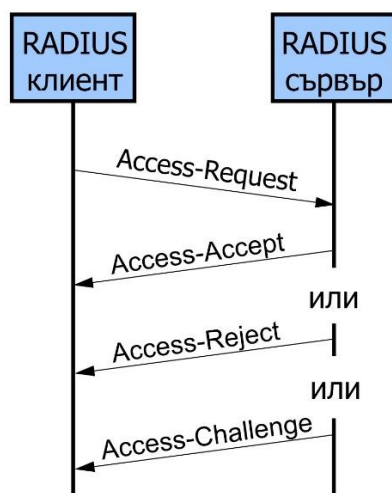
Ролята, реализираща RADIUS протокола в Windows Server, е **Network Policy Server (NPS)**. Когато NPS се използва като RADIUS сервър, процесите по удостоверяването, упълномощаването и управлението следват следните стъпки (Фиг.1.2):

1) Когато потребител достъпва точка за достъп или VPN сървър, се създава заявка за достъп, която се изпраща към NPS (*Access-Request*). Заявката съдържа информация за идентификация под формата на потребителско име и парола, или сертификат за сигурност, предоставен от потребителя.

2) NPS извършва оценка на заявката.

3) В зависимост от резултата на оценката, NPS отговаря с три възможни съобщения:

- *Access-Accept* – На потребителя се предоставя достъп. След като потребителят бъде удостоверен, RADIUS сървърът проверява дали той е упълномощен да използва заявения мрежов ресурс или услуга.
- *Access-Reject* – На потребителя се отказва достъп до заявените мрежови ресурси или услуги. Причините могат да включват невъзможност за предоставяне на правилни потребителско име и парола или използване на неактивен/заклучен потребителски профил.
- *Access-Challenge* – Изисква се допълнителна информация от потребителя, като вторична парола, PIN, token или карта. *Access-Challenge* се използва и в по-сложни обмени на съобщения за удостоверяване, при които се изгражда сигурен тунел между устройството на потребителя и RADIUS сървъра, с цел информацията за удостоверяването да бъде скрита от RADIUS клиента.



Фиг.1.2. Обмен на съобщения между RADIUS сървър и клиент

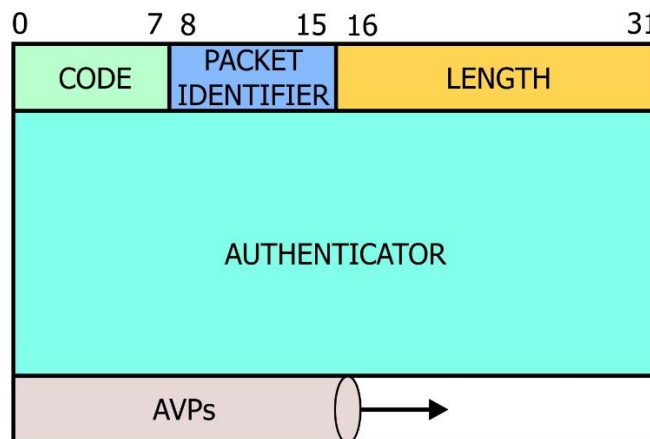
Освен гореспоменатите четири типа съобщения, RADIUS протоколът поддържа и допълнителни, идентифицирани от уникален код (таблица 1).

Таблица 1. Типове RADIUS съобщения

Код	Означение	Код	Означение	Код	Означение
1	Access-Request	11	Access-Challenge	42	Disconnect-NAK
2	Access-Accept	12	Status-Server (експериментален)	43	CoA-Request
3	Access-Reject	13	Status-Client (експериментален)	44	CoA-ACK
4	Accounting-Request	40	Disconnect-Request	45	CoA-NAK
5	Accounting-Response	41	Disconnect-ACK	255	Резервиран

На фиг.1.3 е изобразена структурата на RADIUS пакетите. Полетата в пакета са както следва:

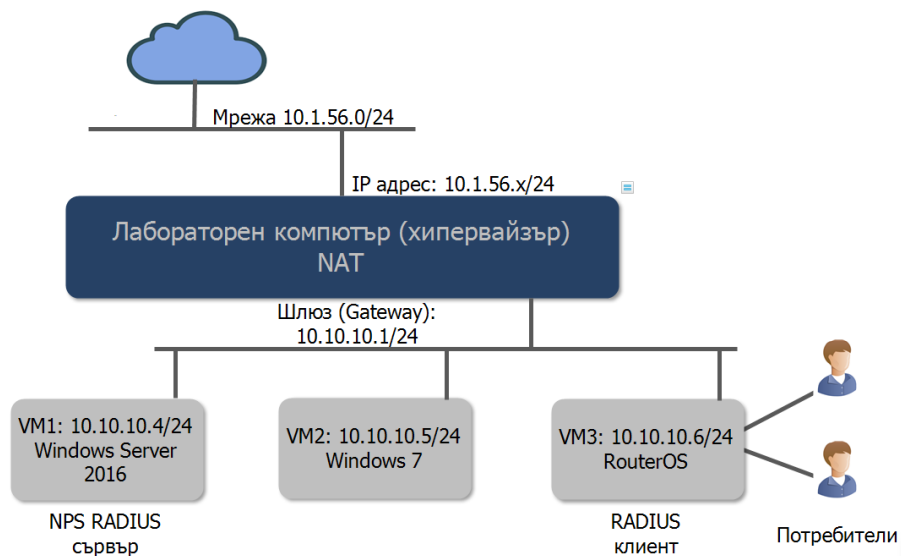
- *Code* – функционален код, определящ типа на RADIUS съобщението (таблица 1).
- *Packet Identifier* – идентифицира пакета и позволява на RADIUS сървърите да откриват дублирани съобщения
- *Length* – специфицира дължината на пакета
- *Authenticator* – полето е с дължина от 16 октета и се използва за удостоверяване и включва хеширани символни низове на паролите.
- *AVPs (Attribute Value Pairs)* – широк набор от атрибути свързани с процеса по обмен на съобщения, удостоверяването, оторизирането и контрола. Примери са IP адреса на RADIUS клиента изискващ удостоверяването, тип на услугата за достъп, мрежовите настройки, които трябва да бъдат назначени на потребителя, както максималната големина на съобщенията (MTU), които потребителят ще може да обмена.



Фиг.1.3. Структура на RADIUS пакет

2. Лабораторна среда

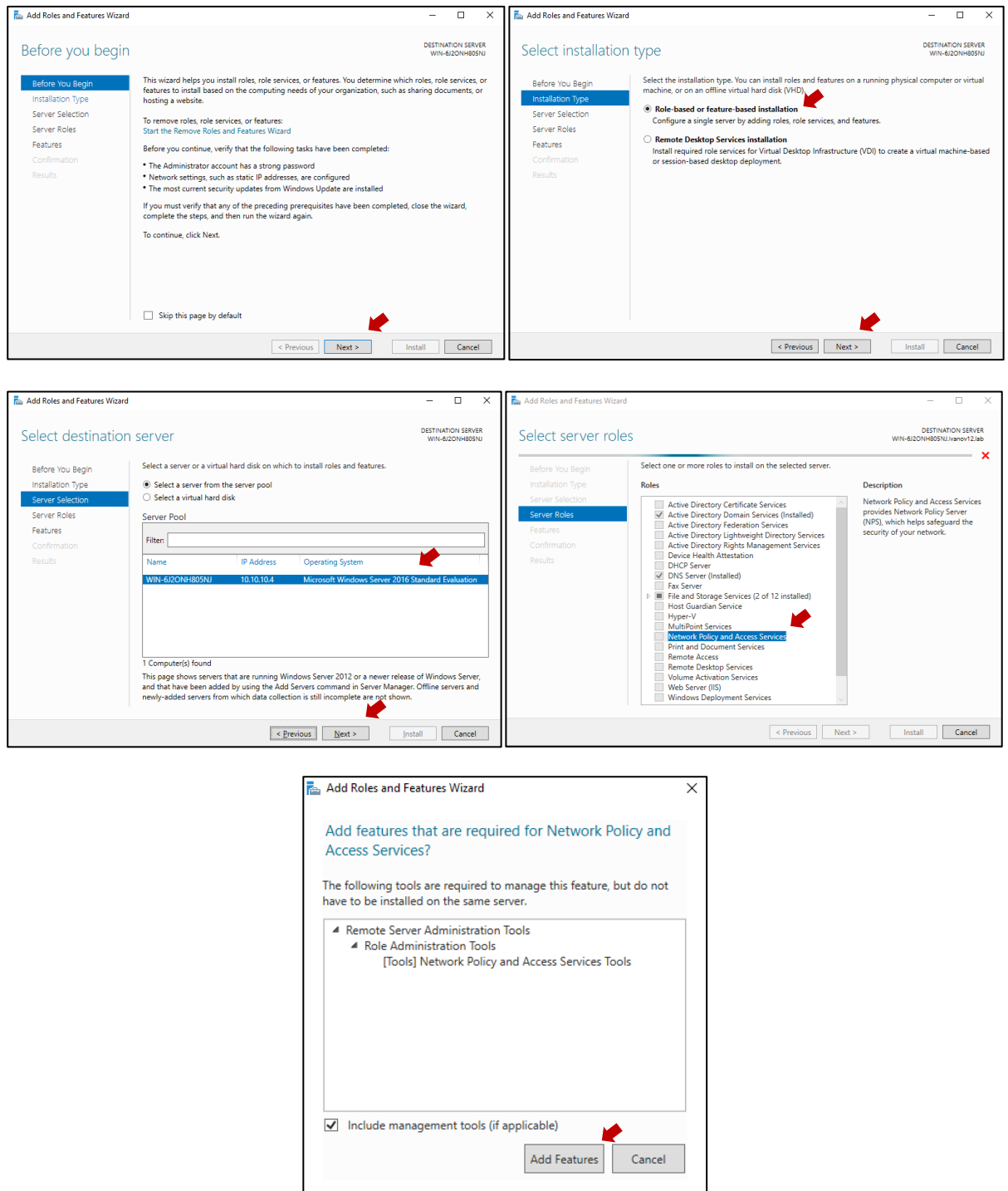
Към вече съществуващата NAT мрежа ще бъде добавена трета виртуална машина, работеща с мрежовата операционна система RouterOS. В Windows Server 2016 виртуалната машина ще бъде настроен и стартиран NPS сървър, който чрез RADIUS протокола трябва да удостоверява потребителите на RouterOS маршрутизатора.



Фиг.2.1. Виртуализационна среда

3. Добавяне и стартиране на Network Policy Server в Windows Server 2016

Посредством Server Manager стартирайте Add Roles and Features Wizard. В прозореца **Before You Begin** изберете Next. Уверете се, че в прозореца **Select Installation Type** е избрана опцията **Role-based or feature-based installation**. В прозореца **Server Selection** трябва да бъде посочен текущият сървър. В **Select Server Roles** посочете ролята **Network Policy and Access Services**. Използвайте настройките по подразбиране в следващите прозорци и изчакайте инсталацията да приключи.



Фиг.3.1.

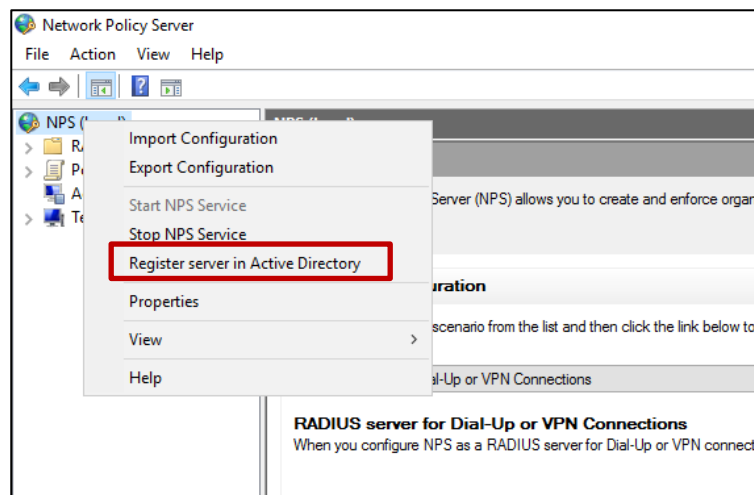
4. Добавяне на потребители за удостоверяване чрез RADIUS

След приключване на инсталацията на ролята, в **Server Manager** изберете **Tools → Active Directory Users and Computers** и добавете два потребителя с потр. имена **RADIUSuser1** и **RADIUSuser2** с пароли **ma@2024**. Обединете двата потребителя в група **RADIUSusers**.

5. Конфигурация на NPS за удостоверяване чрез RADIUS

5.1) Регистриране на NPS в активната директория

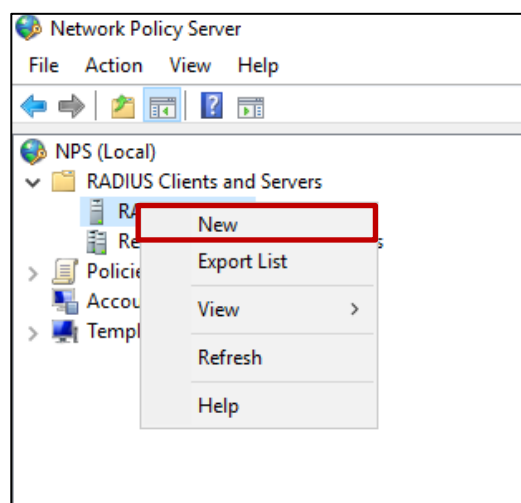
Посредством **Tools** в **Server Manager** стартирайте **Network Policy Server** конфигурационния прозорец. С десен бутон върху **NPS (local)** → изберете **Register server in Active Directory**. Това позволява съществуващите потребители, дефинирани в ADDS да бъдат удостоверявани чрез RADIUS.



Фиг.5.1. Регистриране на NPS в активната директория

5.2) Дефиниране на RADIUS клиента (VM3 с RouterOS) в NPS

В NPS (local), разширете **RADIUS Clients and Servers** и щракнете с десен бутон върху **RADIUS Clients**, след което изберете **New**.



Фиг.5.2.

Въведете настройките на клиента:

- Friendly name: **RADIUSclient**
- Address (IP or DNS): **10.10.10.6** (IP адресът, който ще бъде назначен на VM3)
- Shared secret (и Confirm shared secret): **ma@2024** (парола за удостоверяване на самия RADIUS клиент, но не и на потребителите в активната директория)

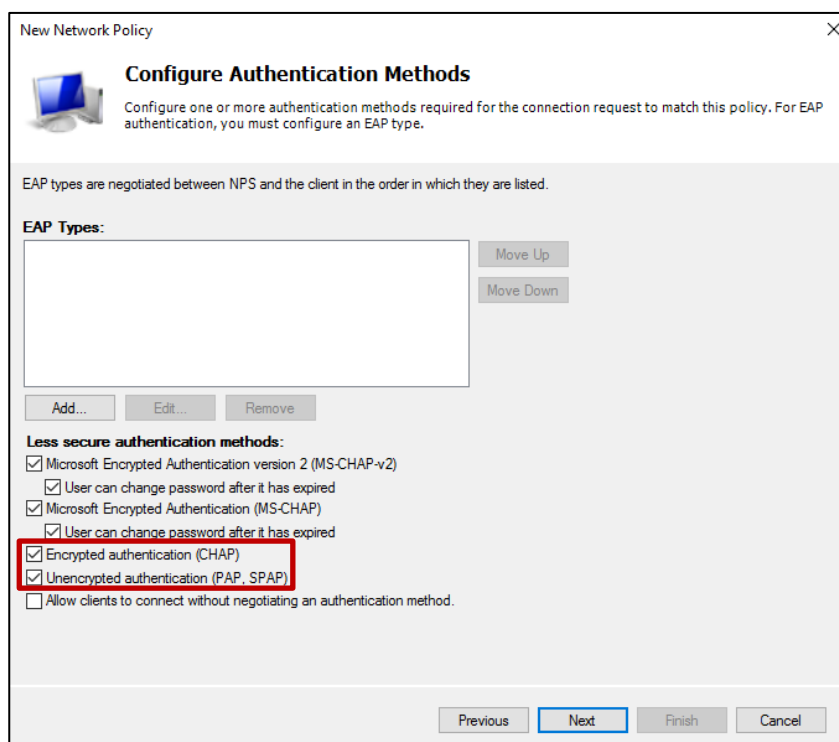
5.3) Създаване на мрежова политика (Network Policy) за удостоверяване на потребителите на RADIUS клиента

Разширете **Policies** → десен бутон върху **Network Policies** → **New**. Задайте наименование на мрежовата политика: **RADIUSpolicy**. Оставете **Type of network access server** по подразбиране (Unspecified).

В прозореца за посочване на условия (Conditions) добавете вече създадената група от потребители **RADIUSusers** (бутон Add... → User Groups → Add Groups, след което въведете нужната група).

В следващия прозорец се уверете, че е избран радио бутонът Access granted (разрешен достъп).

В прозореца за избор на методите за удостоверяване добавете отметки на **Encrypted authentication (CHAP)** и **Unencrypted authentication (PAP, SPAP)**, фиг.5.3. В следващия диалогов прозорец изберете **No**. Завършете задаването на мрежовата политика с настройките по подразбиране.



Фиг.5.3.

6. Конфигурация на RouterOS за работа като RADIUS клиент

Извършете пълно клониране на виртуалната машина RouterOS CHR, като и зададете наименование xxxxxxxx_RouterOS CHR (заменете xxxxxxxx с вашия факултетен номер). Поставете отметка на **Reinitialize the MAC address of all network cards**.

След приключване на клонирането, присъединете виртуалната машина към вече създадената NAT мрежа MA_NetworkXX.

Стартирайте клонираната виртуална машина и влезте в локалния администраторски профил чрез потр. име **admin** и парола **ma@2024**.

Изпълнете следните команди в терминала на операционната система:

- Задаване на хост име (RADIUSclient):

```
/system identity set name=RADIUSclient
```

- Изключване на DHCP клиента на маршрутизатора (ще се използват само статични адреси):

```
/ip dhcp-client remove 0
```

- Задаване на IP адрес на първи интерфейс ether1 (10.10.10.6/24):

```
/ip address add interface=ether1 address=10.10.10.6/24
```

- Добавяне на маршрут по подразбиране за достъп до външни мрежи:

```
/ip route add dst-address=0.0.0.0/0 gateway=10.10.10.1
```

- Добавяне на DNS сървър (VM1) и разрешаване на маршрутизатора да обработва DNS заявки:

```
/ip dns set server=10.10.10.4 allow-remote-requests=yes
```

- Включване на RADIUS поддръжката:

```
/user aaa set use-radius=yes
```

- Стартиране на RADIUS клиент и задаване системните потребители да бъдат удостоверявани чрез NPS RADIUS сървъра:

```
/radius add service=login address=10.10.10.4 secret=ma@2024  
authentication-port=1812 accounting-port=1813
```

- Проверка на връзката с NPS сървъра (изпълнението се прекратява с **ctrl+c**):

```
ping 10.10.10.4
```

7. Проверка на работоспособността на конфигурираните RADIUS клиент и сървър

Уверете се, че само локалният администраторски профил (admin) фигурира в конфигурацията на маршрутизатора:

```
/user print
```

Изпълнете `/quit` и се опитайте да влезете обратно в маршрутизатора чрез добавените в активната директория потребители **RADIUSuser1** и **RADIUSuser2**.

8. Трафичен анализ на RADIUS комуникацията чрез Wireshark

8.1) Инсталирайте трафичния анализатор **Wireshark** на виртуалната машина с Windows Server 2016 (VM1). За улеснение можете да използвате **Shared Folders** функционалността в VirtualBox за да прехвърляте файлове между хост системата и виртуалната машина.

8.2) Добавете самостоятелно нов RADIUS клиент в NPS сървъра, който ще представлява виртуалната машина с Windows 7 (VM2).

8.3) Стартирайте процеса по прихващане на трафик в Wireshark и задайте трафичен филтър RADIUS.

8.4) Стартирайте **NTRADping** в Windows 7, представляващо софтуерно приложение за диагностика на RADIUS протокола чрез ръчно изпращане на съобщения към сървъра. Попълнете нужната информация (IP адрес на сървъра, парола на RADIUS клиента, потр. име и парола на един от двата потребителя (RADIUSuser1 или RADIUSuser2)). За порт за удостоверяване, използвайте 1812. Изпращането на заявките се извършва чрез натискане на бутона **Send**.

8.5) Посредством Wireshark определете типа и функционалния код на обменяните съобщения (вж. таблица 1).